

Status

Proposed

Context

S2PNexus is a multi-tenant, enterprise SaaS Source-to-Pay platform handling sensitive supplier, financial, and personal data across regulated industries and geographies. ADR-0002 through ADR-0005 each reference security concerns, including RBAC, tenant isolation, and audit, without a unifying standard.

Enterprise customers, especially in regulated industries, require a documented, consistent security and compliance posture before procurement. Ad hoc, per-feature security decisions create inconsistency, audit gaps, and sales and procurement friction. This ADR establishes the platform-wide security and governance standard that all other services, including the Approval Engine, Form Engine, Metadata Engine, and Integration Platform, must comply with.

Decision

Establish a Universal Security & Governance framework as the binding standard for multi-tenancy, access control, data protection, compliance, resilience, and observability across S2PNexus. All new services and ADRs must state compliance with this standard or explicitly document exceptions.

Multi-Tenancy

- Strict logical, and where required physical, tenant isolation at the data, compute, and cache layers
- Tenant ID enforced at the data access layer, not only at the application layer, to prevent cross-tenant leakage
- Per-tenant encryption key option for regulated customers, including bring-your-own-key and customer-managed keys
- Tenant-level configuration isolation across metadata, workflows, and integrations, with no shared mutable state across tenants

RBAC and Segregation of Duties

- Role-based access control with fine-grained, object-level and field-level permissions, integrating with the field classification defined in ADR-0004
- Segregation of Duties enforcement, for example a requester cannot approve their own requisition, and a vendor creator cannot also approve vendor payment terms
- Segregation of Duties conflict detection and reporting, identifying which users hold conflicting role combinations
- Attribute-based access control extensions for conditional access, such as business unit, region, or spend threshold
- Just-in-time, time-bound elevated access for administrative actions, with automatic expiry

Data Residency and Sovereignty

- Tenant-selectable data residency regions, such as US, EU, or APAC, chosen at provisioning time
- Data residency guarantees extend to backups, logs, and analytics pipelines, not only to primary storage
- Cross-border data transfer controls consistent with GDPR Chapter V, including Standard Contractual Clauses where applicable

Encryption

- Encryption at rest, AES-256 or equivalent, for all persistent stores including backups
- Encryption in transit, TLS 1.2 or higher, for all internal and external communication
- Field-level encryption for data classified PII, Confidential, or Financial per the ADR-0004 classification tags
- Key management via a dedicated KMS or HSM, with a defined key rotation policy

Secrets Management

- No secrets, including API keys, credentials, or tokens, stored in code, configuration files, or plaintext database columns
- Centralized, vault-based secrets management with scoped access and automatic rotation
- Integration credentials for ERP adapters and external validation providers, per ADR-0005, are stored and rotated via the same vault

Audit and Compliance

- Immutable, tamper-evident audit log for all create, update, and delete actions on business objects, approvals, metadata changes, and access to classified data
- Audit retention policy aligned to regulatory requirements, for example seven years for financial records, and configurable per tenant
- Regular third-party penetration testing and vulnerability scanning cadence
- Data Subject Access Request tooling for GDPR and CCPA, supporting export and deletion of personal data across all services, including custom fields from ADR-0004 and form responses from ADR-0003
- A defined policy for resolving conflicts between right-to-erasure requests and financial or audit retention obligations, with legal hold taking precedence where required

Compliance Coverage

Framework	Scope
SOC 2 Type II	Security, availability, and confidentiality of the platform
ISO 27001	Information security management system
GDPR	EU personal data protection
CCPA	California consumer data privacy
Industry-specific (future)	Extensible to frameworks such as HIPAA or PCI-DSS as needed

Backup and Disaster Recovery

- Defined Recovery Point Objective and Recovery Time Objective targets per service tier
- Automated, tested backups with periodic restore drills, not merely backup existence
- Multi-region failover strategy for the platform availability tier
- Documented incident response and business continuity plan

Observability

- Centralized structured logging, metrics, and distributed tracing across all services, with correlation IDs from ADR-0005 flowing through to security and audit logs

- Security monitoring for anomaly detection, including unusual access patterns, brute-force attempts, and privilege escalation
- SIEM integration available for enterprise customers requiring log export
- Uptime and availability SLA monitoring with a public status page

Architecture Principles

- Security and compliance are platform capabilities, not per-feature afterthoughts; every new ADR must reference this document
- Least privilege by default, with a deny-by-default access model
- Defense in depth: no single control at the network, application, or data layer is the sole safeguard
- Privacy and security by design: classification and access control decisions, per ADR-0004, are made at data-model design time rather than retrofitted

Non-Functional Requirements

- Availability SLA target, for example 99.9 percent, with defined maintenance windows
- RPO and RTO targets by service tier
- Audit log query performance target, since logs must remain queryable for compliance investigations rather than only archived
- Defined key rotation frequency

Consequences

Positive: provides a single enterprise security narrative for sales, procurement, and audits, reduces the risk of inconsistent controls across services, and accelerates compliance certification.

Negative: imposes upfront design constraints on every other ADR, for example field classification in ADR-0004 and credential handling in ADR-0005, which may slow initial delivery. Customer-managed keys and data residency options add operational complexity and cost.

Alternatives Considered

- Per-service, ad hoc security decisions: rejected, as this is already causing inconsistency across ADR-0002 and ADR-0003 and does not scale to enterprise compliance requirements
- Relying entirely on cloud provider default security controls: rejected as insufficient for Segregation of Duties, field-level classification, and tenant-specific compliance needs unique to procurement data

Dependencies and Related ADRs

- ADR-0002: Approval Engine Segregation of Duties rules are enforced via this framework
- ADR-0003: form responses are classified and access-controlled per this standard, for example signature and PII fields
- ADR-0004: data classification tags defined there are enforced by this framework through encryption, masking, and retention
- ADR-0005: all integration credentials, API authentication, and webhook signing follow this standard

Open Questions

- Which compliance certifications are launch-blocking versus roadmap, given that SOC 2 Type II typically requires six to twelve months of evidence?
- Do all tenants receive data residency choice, or is it tier-gated?
- What is the customer-managed key rollout plan, and which tiers require it?